COMPTIA SECURITY+ SY0-701 DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Spyware & Bloatware

Mestre CyberSec · **Aula 2.4 — Spyware & Bloatware** (4:21) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Spyware: coleta informação sem teu knowledge (tracking, keylogger de software). Bloatware: software pré-instalado inútil (superfície extra). Adware: propaganda. PUP: Potentially Unwanted Program. Defesa: AV com anti-spyware, política de instalação, avaliar permissão de apps.

💡 Highlights que a prova CompTIA cobra

- Spyware: coleta SENHA SEM autorização; bloatware: pré-instalado inútil
- PUP (Potentially Unwanted) 'não é malware, mas você NÃO pediu'

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'tracks user behaviour without consent' = spyware

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Spyware & Bloatware)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Spyware (Programa Espião)

Malware que coleta de forma oculta informações do usuário e de sua atividade — hábitos de navegação, credenciais e dados pessoais — sem seu conhecimento ou consentimento.

⚠️ ***Armadilha CompTIA:*** *Gatilho literal da prova: 'tracks user behavior without consent' = spyware. Coleta silenciosa e secreta = spyware; não confunda com adware (foco em anúncios) nem com PUP (indesejado, mas não secreto).*

• Keylogger (Registrador de Teclas)

Variante de spyware, implementado em software ou como dispositivo físico no cabo do teclado, que registra cada tecla digitada para capturar senhas e outras entradas sensíveis.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'registra teclas / senha digitada' = keylogger. Pegadinha clássica: keylogger de HARDWARE existe — a prova pode descrever dispositivo físico inserido entre teclado e computador, não só software.*

• Bloatware (Software Pré-instalado Inútil)

Software desnecessário pré-instalado por fabricantes ou operadoras; não é inerentemente malicioso, mas consome recursos e aumenta a superfície de ataque do dispositivo.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'pré-instalado e inútil' = bloatware. Pegadinha: bloatware NÃO é malware por definição — o risco do exame é a superfície de ataque EXTRA que cada aplicativo inútil adiciona ao sistema.*

• Programa Potencialmente Indesejado (PUP)

Software que o usuário não solicitou explicitamente, frequentemente empacotado em outros instaladores; não é classificado como malware, mas deve ser avaliado e removido.

⚠️ ***Armadilha CompTIA:*** *Citação de prova: 'is not malware, but you did NOT ask for it' = PUP. Distinção-chave: PUP = indesejado (você sabe que está lá, não quer); spyware = oculto (você nem sabe que está coletando).*

• Adware (Software de Publicidade)

Software que exibe publicidade indesejada e pop-ups, frequentemente classificado junto com PUPs; também pode traçar o perfil de navegação para direcionar anúncios.

⚠️ ***Armadilha CompTIA:*** *Foco em propaganda/pop-ups = adware. Lógica da prova: adware vende atenção (anúncios); spyware rouba informação (coleta sem consentimento). Se a questão diz 'without consent', pense spyware.*

• Cookie de Rastreamento

Cookie que acompanha o usuário por múltiplos sites para construir um perfil comportamental de navegação — técnica de rastreamento comum associada ao spyware.

⚠️ ***Armadilha CompTIA:*** *'Monitors browsing/surfing habits' pode ser tracking. Distinção fina: cookie rastreia navegação web; keylogger rastreia teclas; spyware é o guarda-chuva da coleta sem consentimento.*

• Antimalware (Antispyware)

Software de proteção de endpoint (antivírus moderno com recursos antispyware) que detecta, coloca em quarentena e remove spyware, adware e PUPs.

⚠️ ***Armadilha CompTIA:*** *Mitigação padrão na prova: manter anti-malware/anti-spyware ATUALIZADO. O SY0-701 usa a nomenclatura moderna 'anti-malware' em vez de somente 'antivirus' — reconheça os dois como equivalentes.*

• Política de Instalação de Aplicativos (Revisão de Permissões)

Regras administrativas que limitam quais aplicativos podem ser instalados e exigem avaliação das permissões antes da aprovação, como questionar um app de lanterna que pede acesso aos contatos.

⚠️ ***Armadilha CompTIA:*** *Mitigação de bloatware/PUP = política de instalação + revisão de permissões. Sinal de alerta no exame: permissão incongruente com a função do app (lanterna pedindo contatos ou localização) = não instalar.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Keyloggers (Hardware vs. Software) & Screen Scrapers

🏠 **Analogia Intuitiva:** O Keylogger de hardware é como um espião conectar um gravador físico de fita minúsculo exatamente entre o cabo do seu telefone fixo e a tomada da parede: cada palavra falada é gravada no chip do aparelhinho antes mesmo de a voz viajar pelos fios da operadora. O Keylogger de software é como um passageiro invisível sentado no banco do carona que anota em um bloco de notas cada botão que o motorista pressiona no painel do carro. Já o Screen Scraper é um fotógrafo posicionado na janela que tira fotos periódicas em alta resolução do painel e do volante: mesmo que você use um teclado virtual na tela para não apertar botões físicos, o fotógrafo registra o local exato onde você colocou o dedo na tela!

🔍 **Causa Raiz / Por que foi criado:** Bancos e serviços corporativos investem fortunas em criptografia robusta (TLS/HTTPS). No entanto, a interação humana (digitar teclas e visualizar a tela) ocorre antes da criptografia ser aplicada no tráfego de rede. Keyloggers interceptam as interrupções de hardware da porta USB ou injetam ganchos nas APIs de entrada do sistema operacional (SetWindowsHookEx), roubando senhas em texto puro antes que elas cheguem ao navegador.

🛡️ **Visão do Auditor de GRC:** Para keyloggers de hardware: inspeção física periódica das portas USB traseiras de computadores em ambientes críticos (caixas de atendimento, guichês, salas de controle). Para keyloggers e screen scrapers de software: implantar autenticação multifator resistente a phishing (FIDO2 / chaves de segurança de hardware), onde o roubo de senhas estáticas torna-se inútil para o invasor; e monitorar via EDR ganchos anômalos de API e injeção de bibliotecas DLL.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'credentials stolen from a secure HTTPS banking session because an unauthorized process intercepted keystrokes at the operating system layer'. Resposta: Keylogger. Trigger: 'malware circumvents an on-screen graphical virtual keyboard by taking rapid snapshots of the user display'. Resposta: Screen Scraper.

📌 Adware vs. Programas Potencialmente Indesejados (PUP / PUA)

🏠 **Analogia Intuitiva:** O Adware é como um homem-sanduíche inconveniente que pula na sua frente na calçada a cada dez passos jogando panfletos de compras no seu rosto e redirecionando à força a rota do ônibus em que você está para passar na porta de uma loja parceira. O PUP (Programa Potencialmente Indesejado) é como você contratar um técnico para consertar o ar-condicionado da sua sala e, sem avisar abertamente, ele traz três colegas barulhentos que montam acampamento na sua cozinha, ligam televisores no volume máximo e começam a fiscalizar as suas correspondências. Eles alegam cinicamente que 'estava escrito nas letrinhas minúsculas do rodapé da ordem de serviço que eles podiam ficar ali'.

🔍 **Causa Raiz / Por que foi criado:** Desenvolvedores de softwares utilitários gratuitos (freeware) monetizam seus produtos realizando parcerias com redes de publicidade e telemetria (software bundling). Eles utilizam padrões enganosos de design ('Dark Patterns') nos instaladores, como caixas de seleção pré-marcadas em fontes minúsculas, para induzir o usuário desatento a consentir com a instalação de utilitários de monitoramento, barras de ferramentas e mineradores secundários.

🛡️ **Visão do Auditor de GRC:** Configurar políticas corporativas rigorosas de gestão de endpoints que bloqueiem o download e execução de binários não homologados por usuários padrão; implantar soluções de antivírus corporativo com módulo de detecção de PUA/PUP ativado por padrão; e aplicar políticas de grupo (GPO/MDM) travando navegadores contra a instalação de extensões de terceiros não aprovadas.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'intrusive pop-up advertising that hijacks browser default search engines and degrades network bandwidth'. Resposta: Adware. Trigger: 'software bundled alongside a legitimate free utility that installs secondary search bars and tracking modules without transparent user disclosure'. Resposta: Potentially Unwanted Program (PUP / PUA).

📌 Bloatware de Firmware e Dispositivos Novos (OEM Bloatware & Supply Chain)

🏠 **Analogia Intuitiva:** Imagine comprar um automóvel novo zero quilômetro na concessionária e descobrir que a montadora já instalou de fábrica no painel 20 rádios adicionais tocando comerciais que você nunca pediu, um porta-malas entulhado de peças pesadas de fornecedores parceiros que você não usa e uma trava elétrica defeituosa que qualquer chave micha consegue abrir. Essas tralhas pesam no carro, aumentam o consumo de combustível, diminuem a velocidade e, para piorar, criam portas vulneráveis para ladrões arrombarem o veículo.

🔍 **Causa Raiz / Por que foi criado:** Fabricantes de computadores e smartphones (Original Equipment Manufacturers - OEMs) fecham acordos comerciais lucrativos para pré-instalar versões de teste de antivírus, utilitários proprietários de suporte e joguinhos promocionais na imagem de fábrica do hardware. Esses utilitários frequentemente rodam com privilégios máximos de SYSTEM/Root, utilizam mecanismos inseguros de atualização automática pela internet e quase nunca recebem correções de vulnerabilidade, ampliando enormemente a superfície de ataque da empresa.

🛡️ **Visão do Auditor de GRC:** A regra de ouro de governança para aquisição de novos equipamentos é o processo de 'Imagem Padronizada Corporativa' (Corporate Golden Image / Reimaging): nenhum notebook ou servidor recém-saído da caixa deve ser entregue aos usuários com a imagem de fábrica do fornecedor. O disco deve ser formatado e reimagiado com uma imagem corporativa enxuta, auditada e homologada pela equipe de segurança cibernética.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'enterprise purchases 500 new vendor laptops that come pre-loaded with unnecessary trial utilities and manufacturer software that introduce security vulnerabilities'. Resposta: Bloatware. Solução de GRC recomendada na CompTIA: Deploy a clean corporate baseline image / Reimage the systems before deployment.

📌 Implicações de Privacidade e Riscos Regulatórios (LGPD / GDPR Non-Compliance)

🏠 **Analogia Intuitiva:** Colocar uma microcâmera escondida no vestiário de um clube para filmar os frequentadores sem autorização é uma violação gravíssima da intimidade e dignidade humana. No ambiente corporativo, a presença de Spyware ou utilitários ocultos que gravam o que os funcionários digitam, monitoram o histórico de navegação e exfiltram dados pessoais sem base legal é o equivalente exato a essa câmera no vestiário: uma violação frontal às leis de privacidade que pode gerar processos judiciais pesados e multas governamentais capazes de quebrar a organização.

🔍 **Causa Raiz / Por que foi criado:** A coleta opaca e indiscriminada de dados pessoais por softwares de espionagem, cookies invasivos de terceiros e telemetria descontrolada viola os princípios fundamentais da legislação de proteção de dados: finalidade específica, minimização da coleta e transparência/consentimento dos titulares de dados.

🛡️ **Visão do Auditor de GRC:** O auditor de GRC e o Encarregado pelo Tratamento de Dados (DPO) devem conduzir Relatórios de Impacto à Proteção de Dados (RIPD / DPIA), auditar inventários de dados para garantir que Dados Pessoais Identificáveis (PII) e dados sensíveis não estejam sendo coletados por ferramentas não autorizadas, assegurando conformidade com a LGPD (Lei 13.709/18) e GDPR europeu (evitando multas que podem atingir 2% a 4% do faturamento global da empresa).

⚠️ **Como cai na Prova CompTIA:** Trigger: 'unauthorized tracking software collects personally identifiable information (PII) without user knowledge, exposing the organization to significant legal liabilities and regulatory penalties'. Resposta: Privacy violation / Regulatory compliance risk (GDPR/LGPD).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Dispositivo clandestino instalado entre o teclado USB e a máquina que grava senhas de portais bancários antes da cifra HTTPS	**Keylogger de Hardware (Hardware Keylogger)**
Código malicioso que tira prints periódicos do monitor para roubar senhas digitadas em teclados virtuais na tela	**Capturador de Tela (Screen Scraper)**
Software gratuito que instala barras de ferramentas e utilitários extras através de caixas pré-marcadas em letras miúdas	**Programa Potencialmente Indesejado (PUP / PUA)**
Laptops corporativos recém-comprados vêm de fábrica com dezenas de softwares promocionais que aumentam a superfície de ataque	**Bloatware (remediação: formatar e aplicar Imagem Corporativa / Reimage)**
Pop-ups comerciais incessantes e redirecionamento não autorizado do mecanismo de busca no navegador do usuário	**Adware**
Software espião coletando dados pessoais identificáveis (PII) sem consentimento do titular, gerando risco de multas graves	**Violação de Privacidade e Riscos Regulatórios (LGPD / GDPR)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma administradora de folha de pagamento de uma empresa financeira relata que as credenciais do banco online dela foram usadas para transferir fundos sem o conhecimento dela. A análise forense da estação de trabalho revela um processo oculto em segundo plano que capturou tudo o que ela digitou, incluindo senhas, e enviou os dados para um servidor externo. Qual tipo de malware é responsável por este incidente?

A) Ransomware que criptografou os arquivos da vítima e exigiu pagamento

B) Um keylogger de software, que é uma categoria de spyware

C) Um worm polimórfico que se autorreplicou pela rede

D) Um vírus de setor de boot que corrompeu o registro mestre de inicialização

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa comprou 200 notebooks diretamente de um fabricante. A equipe de segurança descobre que os dispositivos vêm de fábrica com dezenas de aplicativos pré-instalados que a empresa nunca usará: antivírus em versão de teste, barras de compras e utilitários promocionais do fornecedor. Qual ação reduz melhor o risco de segurança resultante antes da implantação?

A) Reimageminar cada dispositivo com uma imagem corporativa padronizada contendo apenas software aprovado

B) Habilitar criptografia de disco completo em cada notebook antes de distribuí-lo aos funcionários

C) Configurar bloqueio de tela nos dispositivos e aplicar uma política de senhas fortes em cada unidade

D) Atualizar todos os aplicativos pré-instalados para as versões mais recentes antes da implantação

QUESTÃO 3 · CENÁRIO DE EXAME

Durante uma revisão de inventário de software, técnicos descobrem que um popular conversor de PDF gratuito baixado por vários funcionários também instalou silenciosamente uma barra de ferramentas do navegador, um utilitário de agendamento e um segundo produto antivírus. Nenhum desses extras foi claramente divulgado durante a instalação, e ninguém na empresa os utiliza. De acordo com o esquema de classificação, como esses extras empacotados devem ser categorizados?

A) Vírus de setor de boot que infectaram a tabela de partições

B) Exploits de dia zero direcionados ao conversor de PDF

C) Programas Potencialmente Indesejados (PUPs)

D) Ferramentas de ataque de negação de serviço distribuída

QUESTÃO 4 · CENÁRIO DE EXAME

Vários funcionários de marketing reclamam que, depois de visitar sites de compras online, veem anúncios desses mesmos produtos em sites completamente não relacionados, e os anúncios os acompanham entre navegadores e dispositivos diferentes. Os logs do proxy web não mostram downloads de malware. Qual mecanismo é o mais provável responsável pela publicidade personalizada?

A) Um keylogger de hardware conectado aos teclados dos funcionários

B) DNS poisoning no resolvedor DNS corporativo

C) Um ataque de session hijacking contra o proxy web

D) Tracking cookies que compartilham um identificador comum entre sites

QUESTÃO 5 · CENÁRIO DE EXAME

A central de suporte recebeu vários chamados do departamento de vendas. Os navegadores dos usuários abrem constantemente anúncios pop-up, as páginas iniciais mudam sozinhas e os resultados de busca são injetados com links patrocinados. Porém, arquivos e aplicativos abrem normalmente e nenhum dado parece ter sido roubado. Qual categoria de malware melhor descreve esta infestação?

A) Adware

B) Crypto-malware

C) Um rootkit

D) Uma bomba lógica

QUESTÃO 6 · CENÁRIO DE EXAME

Sob a nova política de instalação de aplicativos da empresa, uma funcionária solicita aprovação para instalar um utilitário gratuito de lanterna no smartphone corporativo dela. A listagem da loja mostra que o aplicativo solicita permissão para acessar contatos, mensagens SMS, localização precisa e o microfone — muito além do que uma lanterna precisa. Qual é a resposta mais apropriada segundo a política?

A) Aprovar a solicitação, porque as lojas de aplicativos dos fornecedores verificam automaticamente todo aplicativo publicado

B) Aprovar a solicitação, mas instruir a funcionária a recusar todas as solicitações de permissão após a instalação

C) Rejeitar a solicitação, porque as permissões solicitadas são excessivas para a finalidade declarada do aplicativo

D) Aprovar a solicitação e desativar os dados móveis do telefone para que o aplicativo não possa exfiltrar nada

QUESTÃO 7 · CENÁRIO DE EXAME

Uma auditoria constata que os endpoints de uma empresa de logística não têm proteção contra softwares que monitoram silenciosamente a atividade dos usuários. A gerência deseja um único controle que possa tanto detectar softwares de monitoramento conhecidos já presentes nos hosts quanto removê-los automaticamente. Qual controle melhor atende a esse requisito?

A) Habilitar criptografia de disco completo com uma chave de recuperação forte em cada endpoint

B) Implantar uma suíte antimalware com assinaturas antispyware atualizadas em cada endpoint

C) Implementar apagamento remoto e geofencing por meio da plataforma MDM

D) Exigir senhas complexas com expiração em 90 dias para todas as contas dos endpoints

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista de segurança de uma empresa de investimentos está analisando um endpoint suspeito de executar software de monitoramento não autorizado sem o conhecimento do usuário. Qual das observações a seguir sustenta mais fortemente essa suspeita?

A) O disco do sistema da estação de trabalho está totalmente criptografado e a máquina inicializa normalmente

B) O usuário relata pop-ups frequentes de anúncios durante a navegação

C) O cache do navegador contém vários tracking cookies de terceiros

D) Um processo em segundo plano sem janela captura a entrada do teclado e envia periodicamente pequenos payloads criptografados para um IP externo desconhecido

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa compra smartphones para os funcionários diretamente de uma operadora. Os dispositivos incluem muitos aplicativos pré-instalados da operadora e promocionais que não podem ser desinstalados; alguns solicitam acesso à rede e são executados em segundo plano mesmo que os funcionários nunca os abram. Qual é a principal preocupação de segurança com esses aplicativos?

A) Eles ampliam a superfície de ataque, pois software não utilizado pode conter falhas exploráveis ou coleta oculta de dados

B) Eles consomem bateria e armazenamento, reduzindo a vida útil dos dispositivos

C) Eles impedem que o servidor MDM registre os dispositivos no gerenciamento

D) Eles tornam os dispositivos incompatíveis com a plataforma corporativa de e-mail

QUESTÃO 10 · CENÁRIO DE EXAME

No último trimestre, técnicos removeram repetidamente barras de ferramentas, softwares de teste e utilitários indesejados que os funcionários instalaram junto com downloads gratuitos legítimos. A liderança quer um controle preventivo que impeça essas adições, mantendo a permissão para software corporativo aprovado. Qual controle melhor alcança esse objetivo?

A) Publicar um informativo mensal de segurança que descreva técnicas emergentes de spyware

B) Aplicar uma política de instalação de aplicativos que permita apenas software aprovado e exija a revisão das permissões solicitadas

C) Configurar o antivírus para executar verificações de disco completo diariamente em vez de semanalmente

D) Agendar tarefas semanais de limpeza de disco e desfragmentação em cada endpoint

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Um keylogger de software, que é uma categoria de spyware

O processo oculto capturou silenciosamente tudo o que foi digitado — incluindo credenciais — e transmitiu os dados para um servidor controlado pelo atacante. Esse é o comportamento característico de um keylogger de software, um tipo de spyware que coleta informações sem o conhecimento do usuário. Ransomware criptografa arquivos para extorsão, worms se autorreplicam para se espalhar e vírus de setor de boot corrompem o registro de inicialização; nenhum deles rouba credenciais capturando o que é digitado.

Questão 2: Alternativa A — Reimageminar cada dispositivo com uma imagem corporativa padronizada contendo apenas software aprovado

Bloatware é o software indesejado pré-instalado que fornecedores entregam em dispositivos novos. Cada aplicativo não utilizado é código extra que pode conter vulnerabilidades não corrigidas ou coleta oculta de dados, portanto removê-lo reduz a superfície de ataque. Reimageminar com uma build corporativa padrão limpa é a prática recomendada. A criptografia de disco protege dados em repouso, o bloqueio de tela protege o acesso, e apenas atualizar os aplicativos pré-instalados mantém o software desnecessário — e seu risco — no lugar.

Questão 3: Alternativa C — Programas Potencialmente Indesejados (PUPs)

Software que chega empacotado com um download legítimo, instala-se sem divulgação clara e não serve a nenhum propósito corporativo é classificado como Programa Potencialmente Indesejado (PUP). PUPs ampliam a superfície de ataque, consomem recursos e frequentemente carregam adware ou telemetria. Neste cenário eles não são vírus nem exploits, e não têm relação com ataques de DoS; classificá-los como PUPs direciona a remediação correta de remoção e filtragem por política.

Questão 4: Alternativa D — Tracking cookies que compartilham um identificador comum entre sites

Os anúncios acompanham os usuários entre sites não relacionados e até entre navegadores e dispositivos, sem downloads maliciosos detectados. Essa é a assinatura dos tracking cookies: pequenos arquivos que compartilham um identificador persistente com redes de publicidade, que os usam para construir perfis comportamentais e exibir anúncios direcionados. Um keylogger capturaria credenciais em vez de personalizar anúncios, DNS poisoning desvia a resolução de nomes e session hijacking assume sessões ativas — nenhum produz publicidade personalizada entre sites.

Questão 5: Alternativa A — Adware

Pop-ups, páginas iniciais sequestradas e links patrocinados injetados são os sintomas clássicos de adware, que monetiza sistemas infectados forçando publicidade na frente dos usuários. Os arquivos abrem normalmente e nada foi roubado, o que descarta o crypto-malware (que criptografa dados para resgate); não há evidência de código privilegiado oculto típico de um rootkit, e uma bomba lógica executa ações maliciosas quando acionada, não publicidade indesejada contínua.

Questão 6: Alternativa C — Rejeitar a solicitação, porque as permissões solicitadas são excessivas para a finalidade declarada do aplicativo

A revisão de permissões de aplicativos compara cada permissão solicitada à função legítima do aplicativo. Uma lanterna não tem necessidade plausível de accessar contatos, SMS, localização precisa ou microfone; esse excesso é um indicador clássico de que o aplicativo pode espionar o dispositivo, portanto a instalação deve ser rejeitada. A verificação da loja não é garantia de segurança, recusar solicitações após a instalação é pouco confiável, e desativar os dados móveis não resolve as permissões excessivas de dispositivo que o aplicativo já exige.

Questão 7: Alternativa B — Implantar uma suíte antimalware com assinaturas antispyware atualizadas em cada endpoint

Pacotes antimalware modernos incluem capacidade antispyware: com assinaturas e heurísticas atualizadas, eles detectam keyloggers conhecidos, componentes de rastreamento e softwares de monitoramento já presentes em um host, podendo colocá-los em quarentena ou removê-los automaticamente. A criptografia de disco completa protege dados em repouso, o apagamento remoto via MDM protege dispositivos perdidos ou roubados e a política de senhas endurece a autenticação — nenhum desses controles detecta ou remove software de monitoramento já em execução.

Questão 8: Alternativa D — Um processo em segundo plano sem janela captura a entrada do teclado e envia periodicamente pequenos payloads criptografados para um IP externo desconhecido

A marca registrada do spyware de registro de teclas é um processo oculto que grava a entrada do teclado e exfiltra secretamente os dados capturados; pequenos uploads periódicos para um IP desconhecido são o padrão clássico de exfiltração. Pop-ups apontam para adware, tracking cookies de terceiros apontam para rastreamento web e não para

captura local de teclas, e a criptografia de disco completo é um controle protetivo — nada disso indica monitoramento oculto.

Questão 9: Alternativa A — Eles ampliam a superfície de ataque, pois software não utilizado pode conter falhas exploráveis ou coleta oculta de dados

O principal risco de segurança do bloatware é a superfície de ataque ampliada: cada aplicativo pré-instalado é código adicional, muitas vezes inremovível, que executa com privilégios do dispositivo, pode conter vulnerabilidades não corrigidas e pode coletar ou transmitir dados mesmo que o usuário nunca o abra. O consumo de bateria e armazenamento é um inconveniente operacional, não um risco de segurança, e aplicativos pré-instalados normalmente não impedem o registro no MDM nem quebram o e-mail corporativo.

Questão 10: Alternativa B — Aplicar uma política de instalação de aplicativos que permita apenas software aprovado e exija a revisão das permissões solicitadas

Uma política de instalação de aplicativos é o controle preventivo que barra barras de ferramentas, software de teste e utilitários empacotados no ponto de aprovação: apenas software aprovado em lista branca pode ser instalado, e as permissões solicitadas são revisadas antes da instalação. Informativos aumentam a conscientização, mas não impõem nada; verificações de antivírus mais frequentes podem detectar malware conhecido, mas geralmente não detectam PUPs e nunca impedem a instalação; limpeza de disco e desfragmentação são manutenção de desempenho, sem relação com o que é instalado.